

IS-CIRQ-PR-020-G: Incident Response Procedure (Global Core)

Document: IS-CIRQ-PR-020-G

Standards Name: Incident Response Procedure (Global Core)

Category: IT Security Related

Division: Procedure

Standard Retention: Exist and No Corrections

Standard Type: Global

Version: 1.0 **Effective Date:** 2025-07-01 **Review Date:** 2026-07-01 **Approved By:** IT Manager

1. Purpose

The purpose of this procedure is to define the global core process for responding to information security incidents within Cirque. It provides a systematic framework for detecting, analyzing, containing, eradicating, recovering from, and conducting post-incident activities for security incidents, thereby minimizing their impact and facilitating timely recovery, in accordance with IS-CIRQ-P-014-G: Information Security Incident Management Policy and ISO/IEC 27001:2022 Annex A.16.

2. Scope

This procedure applies to all Cirque personnel (employees, contractors, temporary staff) and all information assets, information systems, applications, and networks owned or managed by Cirque across all its global operations (US, Taipei, Japan, China). It covers all suspected or confirmed information security incidents. Localized procedures (IS-CIRQ-PR-020-US, IS-CIRQ-PR-020-JP, IS-CIRQ-PR-020-CN) will provide region-specific details and contacts, but the core steps remain consistent.

3. Definitions

- **Information Security Incident:** A single or a series of unwanted or unexpected information security events that have a significant probability of compromising

business operations and threatening information security (e.g., loss of confidentiality, integrity, or availability).

- **Incident Response Team (IRT):** A designated group of individuals responsible for managing and responding to information security incidents.
- **Containment:** The act of limiting the scope and impact of an incident.
- **Eradication:** The act of removing the cause of the incident.
- **Recovery:** The act of restoring affected systems and services to normal operation.

4. Incident Response Team (IRT)

a. The **Incident Response Team (IRT)** shall be led by the IT Manager and comprise key personnel from IT, Legal, Human Resources, and relevant business units as required by the nature and scope of the incident.

b. The IT Manager is the primary Incident Coordinator.

c. Contact information for IRT members and escalation paths shall be maintained and readily accessible.

5. Incident Response Lifecycle

The incident response process follows a six-phase lifecycle:

5.1. Phase 1: Preparation

a. **Policy & Procedure Development:** Maintain and review this procedure and the `IS-CIRQ-P-014-G: Information Security Incident Management Policy`.

b. **IRT Training:** Ensure IRT members receive regular training on incident response procedures, tools, and roles.

c. **Tools & Resources:** Maintain necessary tools for incident response (e.g., forensic tools, secure communication channels, network diagrams, asset inventories).

d. **Communication Plan:** Develop and maintain communication templates and escalation matrices for internal and external stakeholders.

e. **Testing:** Periodically test incident response capabilities through drills or tabletop exercises.

5.2. Phase 2: Detection and Analysis

- a. **Incident Reporting:** Any individual who suspects or confirms an information security event or incident shall report it immediately to the IT Manager or through designated channels (e.g., `security@cirq.com`, or the IT ticketing system).
- b. **Initial Triage:** The IT Manager or designated IT personnel performs initial assessment to determine if a reported event constitutes an information security incident.
- c. **Gather Information:** Collect relevant information: What happened? When? Where? How was it discovered? Who is affected? What is the potential impact?
- d. **Classification and Prioritization:** Classify the incident based on its severity and potential impact (e.g., Critical, High, Medium, Low) using defined criteria. This determines the urgency and resources required.
- e. **Initial Notification:** Based on severity, notify relevant IRT members and leadership as per the escalation matrix.

5.3. Phase 3: Containment

- a. **Strategy:** Develop a containment strategy to prevent further damage and limit the scope of the incident. This strategy should balance business continuity with security needs.
- b. **Execution:** Implement containment measures, which may include:
 - * Isolating affected systems or networks.
 - * Disabling compromised accounts.
 - * Blocking malicious IP addresses or URLs at firewalls.
 - * Disconnecting affected devices from the network.
 - * Applying temporary patches or workarounds.
- c. **Evidence Preservation:** Preserve digital and physical evidence in a forensically sound manner throughout the containment process. Maintain a strict chain of custody.

5.4. Phase 4: Eradication

- a. **Root Cause Analysis:** Identify and address the root cause of the incident to prevent recurrence. This involves analyzing logs (`IS-CIRQ-PR-015-G: Logging and Monitoring Procedure`), forensic evidence, and system configurations.
- b. **Malware Removal:** Remove malware, backdoors, or unauthorized configurations.

c. **Vulnerability Remediation:** Remediate exploited vulnerabilities (e.g., patching systems, reconfiguring firewalls, hardening applications). Implement changes following `IS-CIRQ-PR-013-G: Change Management Procedure`.

5.5. Phase 5: Recovery

a. **Restoration:** Restore affected systems and data from clean backups (`IS-CIRQ-PR-014-G: Backup and Restoration Procedure`) or re-image systems.

b. **Verification:** Thoroughly test restored systems and data to ensure full functionality and integrity before returning them to production.

c. **Monitoring:** Increase monitoring of recovered systems to detect any resurgence of malicious activity.

d. **Phased Return:** For complex incidents, recovery may be phased, gradually returning systems and services to full operation.

5.6. Phase 6: Post-Incident Activity (Lessons Learned)

a. **Post-Incident Review (PIR):** For all significant incidents, conduct a formal PIR meeting with relevant IRT members and stakeholders.

b. **Documentation:** Document all aspects of the incident, including:

- * Timeline of events.
- * Actions taken during each phase.
- * Root cause analysis and contributing factors.
- * Impact assessment.
- * Lessons learned.

c. **Recommendations:** Develop actionable recommendations for improving security controls, policies, procedures, and incident response capabilities.

d. **Tracking:** Track the implementation of recommendations and corrective actions.

e. **Reporting:** Prepare a final incident report for management and other relevant stakeholders.

f. **Compliance:** Ensure all regulatory and legal notification requirements are met.

6. Communication Strategy

a. ****Internal Communication:**** Maintain regular internal communication with affected departments, management, and the IRT.

b. ****External Communication:**** The IT Manager, in consultation with Legal and Executive Management, will manage all external communications (e.g., to law enforcement, customers, regulatory bodies, media). No unauthorized external communication is permitted.

7. Review and Update

This procedure will be reviewed at least annually, or sooner if there are significant changes to Cirque's IT environment, lessons learned from incidents, or changes in legal/regulatory requirements.

8. Related Documents

- IS-CIRQ-P-014-G: Information Security Incident Management Policy
- IS-CIRQ-PR-015-G: Logging and Monitoring Procedure
- IS-CIRQ-PR-013-G: Change Management Procedure
- IS-CIRQ-PR-014-G: Backup and Restoration Procedure
- IS-CIRQ-F-001-G: Risk Assessment Register
- IS-CIRQ-P-001-G: Information Security Policy
- IS-CIRQ-P-010-G: Physical and Environmental Security Policy